

LPIC-1 · 102-500

Tema 110: Seguridad

Tres subtemas · 10 pesos totales en el examen

110.1 sobre **Peso 3**

Permisos especiales y auditoría

110.2 sobre **Peso 3**

Shadow, pwck y control de servicios

110.3 sobre **Peso 4**

SSH, llaves y GPG

LPIC-1 · 102-500

Índice

Recorrido del Tema 110: tres subtemas, tabla maestra, laboratorio y quiz final.

01 **110.1 · Permisos SUID/SGID/Sticky, sudo/su/ulimit y auditoría**
Diapos 3-5 · Peso 3

02 **110.2 · /etc/shadow, pwck, xinetd vs systemd.socket, hosts.allow/deny**
Diapos 6-7 · Peso 3

03 **110.3 · SSH, llaves ed25519, sshd_config y GPG**
Diapos 8-10 · Peso 4

04 **Tabla maestra de comandos y archivos clave**
Diapo 11

05 **Laboratorio en VM segura**
Diapo 12

06 **Quiz de 5 preguntas + cierre**
Diapos 13-14

02 / 14

110.1 · Peso 3

Permisos especiales: SUID, SGID y Sticky Bit

- **SUID (4000):** ejecuta el binario como su propietario, no como el usuario que lo invoca
- **SGID (2000):** en binarios ejecuta como el grupo propietario; en directorios los archivos nuevos heredan el grupo del directorio
- **Sticky bit (1000):** en directorios compartidos solo el propietario del archivo o del directorio puede borrar archivos (clásico en /tmp)
- **Vigilar binaries SUID inusuales:** posibles vectores de escalada de privilegios

Octal	Símbolo	Permiso	Ejemplo clásico
4000	s en owner	SUID	/usr/bin/passwd
2000	s en group	SGID	/usr/bin/wall (en binarios), /var/shared (dir)
1000	t en other	Sticky	/tmp

```
# Listar permisos especiales
find / -perm -4000 -type f 2>/dev/null   # lista SUID
find / -perm -2000 -type f 2>/dev/null   # lista SGID
find / -perm -1000 -type d 2>/dev/null   # lista sticky en dirs
```

110.1

sudo · su · ulimit

Gestión de privilegios y límites del sistema

sudo

- Ejecuta un comando como root u otro usuario
- Configurado en `/etc/sudoers` (editar con `visudo`)
- Logs en `/var/log/auth.log`

```
sudo -u alice whoami
sudo -l          # lista permisos
```

su

- Cambia a otra cuenta de usuario (shell completa)
- Requiere la contraseña del destino
- `su -` entrega un entorno de login limpio

```
su - root
su - postgres -c 'psql'
```

ulimit

- Límites por shell: CPU, memoria, archivos abiertos
- `ulimit -a` muestra todos
- Persistente en `/etc/security/limits.conf`

```
ulimit -n 4096
ulimit -a
```

110.1

Auditoría de usuarios, sesiones y puertos

WHO

Usuarios conectados ahora

```
who -q
```

W

Quién está activo y qué ejecuta

```
w
```

LAST

Historial de inicios de sesión

```
last -n 20
```

LSOF

Archivos abiertos y puertos asociados

```
lsof -i :22
```

FUSER

Procesos que usan un archivo/puerto

```
fuser -v 22/tcp
```

NMAP + SS

Escaneo local y estado de sockets

```
ss -tlnp
nmap -sT localhost
```

⚠ nmap es una herramienta ofensiva — úsala solo sobre hosts propios o con autorización explícita.

110.2 · PESO 3

Contraseñas en /etc/shadow

Separación de hashes y verificación de integridad

- **/etc/passwd** es legible por todos (world-readable); no debe contener hashes
- **/etc/shadow** almacena el hash + edad de la contraseña + políticas de expiración
- Permisos recomendados: **640 root:shadow** (o 640 root:root)
- El hash usa `$id$salt$hash`: **6** = SHA-512, **y** = yescrypt
- **pwck** valida consistencia entre /etc/passwd y /etc/shadow
- **grpck** hace lo mismo para /etc/group y /etc/gshadow

PERMISOS Y PROPIETARIO

```
sudo chown root:shadow /etc/shadow
sudo chmod 640 /etc/shadow
ls -l /etc/shadow
```

VERIFICACIÓN

```
sudo pwck       # revisa passwd + shadow
sudo grpck      # revisa group + gshadow
```

LÍNEA SHADOW — CAMPOS

```
usuario:$6$xyz$abcd...:19000:0:99999:7:::
# [hash][último cambio][min][max][warn][inactivo][expira]
```

110.2

Servicios de red y TCP Wrappers

xinetd vs systemd.socket

CLÁSICO **xinetd**

- Superdaemon que lanza servicios bajo demanda
  - Config en /etc/xinetd.conf y /etc/xinetd.d/<servicio>
  - Define instancias, límites, logging, control de acceso

MODERNO **systemd.socket**

- Socket activation nativa
  - Unidades *.socket que arrancan el servicio al primer paquete
  - Integrado con journalctl, sin binario puente
  - Más eficiente en sistemas con systemd

```
# Comando para comparar
systemctl list-sockets
systemctl status ssh.socket
```

hosts.allow / hosts.deny

- TCP Wrappers: filtrado por IP/hostname en la **libwrap**

Orden de evaluación CRÍTICO:

1. **/etc/hosts.allow** — coincide → permite
2. **/etc/hosts.deny** — coincide → deniega
3. Si ningún patrón coincide → se permite por defecto

- Por ello **hosts.deny** debe contener `ALL: ALL` como último respaldo

```
# /etc/hosts.allow
sshd: 192.168.1.0/24 127.0.0.1
# /etc/hosts.deny
ALL: ALL
```

! **Regla mnemónica:** ALLOW gana siempre que coincida; DENY actúa de red de seguridad.

110.3 · PESO 4

ssh: opciones esenciales

- `-p PUERTO` — puerto del servidor sshd remoto
- `-i ARCHIVO` — usa una llave privada concreta
- `-L lport:host:port` — túnel local (acceso a un puerto remoto vía local)
- `-R rport:host:port` — túnel remoto (expone un puerto local al servidor)
- `-D [puerto]` — SOCKS dinámico, proxy SOCKS5 local

```
# Puerto y llave
ssh -p 2222 -i ~/.ssh/id_ed25519 user@host

# Túnel local: exponer el PostgreSQL remoto en mi 5432
ssh -L 5432:localhost:5432 user@db.example.com

# Túnel remoto: exponer mi 8080 al servidor remoto en 8080
ssh -R 8080:localhost:8080 user@jump.example.com

# SOCKS5 dinámico en 1080
ssh -D 1080 user@jump.example.com
# Luego: firefox --socks5 127.0.0.1:1080
```

Tip: KeepAlive y salida en segundo plano con `-fN` para túneles persistentes: `ssh -fN -L 5432:localhost:5432 user@host`

110.3

Llaves ed25519 y despliegue con ssh-copy-id

- **ed25519**: algoritmo asimétrico moderno (EdDSA), 256 bits, más corto y rápido que RSA
- Preferido sobre RSA salvo compatibilidad con sistemas antiguos
- La llave privada **NUNCA** sale del equipo del usuario
- La llave pública se copia a `~/.ssh/authorized_keys` del destino

Permisos obligatorios:

700 ~/.ssh/	600 id_ed25519
600 authorized_keys	644 known_hosts

1 GENERAR PAR ED25519

```
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519 -C "alicia@laptop"
# Pide passphrase (recomendado)
```

2 COPIAR LLAVE PÚBLICA AL SERVIDOR

```
ssh-copy-id -i ~/.ssh/id_ed25519.pub user@host
# Equivalente manual:
# cat ~/.ssh/id_ed25519.pub | ssh user@host \
#   'mkdir -p ~/.ssh && chmod 700 ~/.ssh && \
#    cat >> ~/.ssh/authorized_keys && \
#    chmod 600 ~/.ssh/authorized_keys'
```

3 VERIFICAR Y PROBAR

```
ls -l ~/.ssh
ssh -i ~/.ssh/id_ed25519 user@host 'id; hostname'
```

110.3

Endurecer sshd + cifrado con GPG

sshd_config

Archivo: **/etc/ssh/sshd_config**

Tras editar: `sudo sshd -t` (sintaxis) y `sudo systemctl reload sshd`

DIRECTIVAS CLAVE

DIRECTIVA	VALORES	RECOMENDACIÓN LPI
PermitRootLogin	yes / no / prohibit-password	**prohibit-password** (solo llaves)
PasswordAuthentication	yes / no	**no** en producción

```
# /etc/ssh/sshd_config
PermitRootLogin prohibit-password
PasswordAuthentication no
PubkeyAuthentication yes
# Validar y aplicar
sudo sshd -t && sudo systemctl reload sshd
```

GPG: cifrado asimétrico

gpg usa pares pública/privada; cifrar con la pública, descifrar con la privada

COMANDOS ESENCIALES

```
# Generar par
gpg --gen-key
# Listar claves
gpg --list-keys         # públicas
gpg --list-secret-keys  # privadas
# Cifrar (usa la pública del destinatario)
gpg -e -r alice@ejemplo.org secreto.txt
# Descifrar (usa tu privada)
gpg -d secreto.txt.gpg
# Cifrado simétrico (una sola frase)
gpg -c backup.tar.gz
# Exportar/importar pública
gpg --export --armor alice@ejemplo.org > alice.pub
gpg --import alice.pub
```

REFERENCIA

Comandos y archivos que debes recordar

Mapa de referencia rápida para 110.1, 110.2 y 110.3

CATEGORÍA	ARCHIVO / COMANDO	FUNCIÓN	PERMISO / CONFIG
Cuentas	/etc/passwd	Info de usuario (UID, GID, shell)	644 root:root
Cuentas	/etc/shadow	Hash de contraseñas y políticas	640 root:shadow
Cuentas	pwck / grpck	Validar consistencia passwd/shadow	ejecutar como root
Privilegios	/etc/sudoers	Reglas de sudo	editar con visudo, 440
Privilegios	su / sudo	Cambiar usuario / ejecutar como root	sudo -l para auditar
Servicios	/etc/xinetd.d/*	Servicios xinetd	deshabilitar si no se usa
Servidores	/etc/hosts.allow	TCP Wrappers — permitir	se evalúa primero
Servidores	/etc/hosts.deny	TCP Wrappers — denegar	ALL: ALL como red de seguridad
SSH	/etc/ssh/sshd_config	Configuración del servidor sshd	reload tras editar (sshd -t)
SSH	~/.ssh/	Llaves y known_hosts	700 dir · 600 privadas
GPG	gpg -e/-d/-c	Cifrar/descifrar/simétrico	--export/--import para pública

Mnemónico: *"shadow 640, sudoers 440, hosts.deny ALL: ALL, ~/.ssh 700/600".*

LABORATORIO

Práctica en VM aislada (4 pasos)

Snapshot inicial recomendado antes de iniciar

01

Localizar archivos SUID en el sistema

```
find / -perm -4000 -type f 2>/dev/null | sort
```

Compara contra la lista de tu distribución; investiga binarios SUID fuera de /usr/bin estándar.

02

Auditar tus privilegios sudo

```
sudo -l
```

Identifica qué comandos puedes ejecutar como root y verifica la regla en /etc/sudoers con visudo.

03

Generar llave ed25519 y copiar a localhost

```
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519
ssh-copy-id -i ~/.ssh/id_ed25519.pub user@localhost
ssh -i ~/.ssh/id_ed25519 user@localhost
```

Verifica permisos 700/600 con ls -l ~/.ssh.

04

Cifrar y descifrar un archivo con GPG

```
echo 'secreto' > nota.txt
gpg -c nota.txt
gpg -d nota.txt.gpg
```

Prueba también gpg --gen-key y luego -e/-d con la pública de un compañero (en la misma VM).

QUIZ

Comprueba lo aprendido — 5 preguntas

1 **¿Cuál es el principal riesgo de un script shell con SUID?**

RESPUESTA Ejecución con privilegios del propietario y, en scripts, fácil de explotar mediante manipulación de entorno (PATH, IFS).

Por eso muchas distribuciones ignoran SUID en scripts por defecto; solo binarios compilados.

2 **Con hosts.allow y hosts.deny, ¿qué regla gana si una IP coincide en ambos?**

RESPUESTA Gana hosts.allow — se evalúa primero y permite; hosts.deny nunca llega a considerarse.

Si no hay coincidencia en allow, se revisa deny; si tampoco, el acceso se concede por defecto.

3 **¿Qué permiso debe tener tu llave privada SSH?**

RESPUESTA 600 — lectura/escritura solo para el propietario; sshd rechaza llaves más abiertas.

El directorio ~/.ssh va con 700; authorized_keys también 600.

4 **¿Qué significa PermitRootLogin prohibit-password en sshd_config?**

RESPUESTA Root puede entrar, pero solo con autenticación por llave (no con contraseña).

Es más seguro que yes y más práctico que no cuando hay automatización.

5 **En gpg -e -r destinatario archivo, ¿qué llave se usa para cifrar?**

RESPUESTA La llave pública del destinatario; solo su llave privada podrá descifrar.

gpg -c en cambio usa una frase de paso compartida (cifrado simétrico).

CIERRE · TEMA 110 · SEGURIDAD

Seguridad, no casualidad

Tres subtemas, diez pesos, una práctica constante.



LPIC-1 · 102-500

Tema 110: Seguridad

110.1 · 110.2 · 110.3

Recursos oficiales LPI

learning.lpi.org/es/learning-materials/102-500/

lpi.org/es/exam-101-102-objectives/

Aviso ético

Herramientas como nmap, fuser y ss son poderosas y, mal usadas, pueden violar leyes de acceso no autorizado (ej. Computer Fraud and Abuse Act, RGPD, LOPD). Úsalas solo en redes y hosts que te pertenezcan o para los que tengas autorización explícita por escrito.

Próximo paso: realiza el laboratorio en VM, documenta tus hallazgos y repasa el quiz antes del examen.